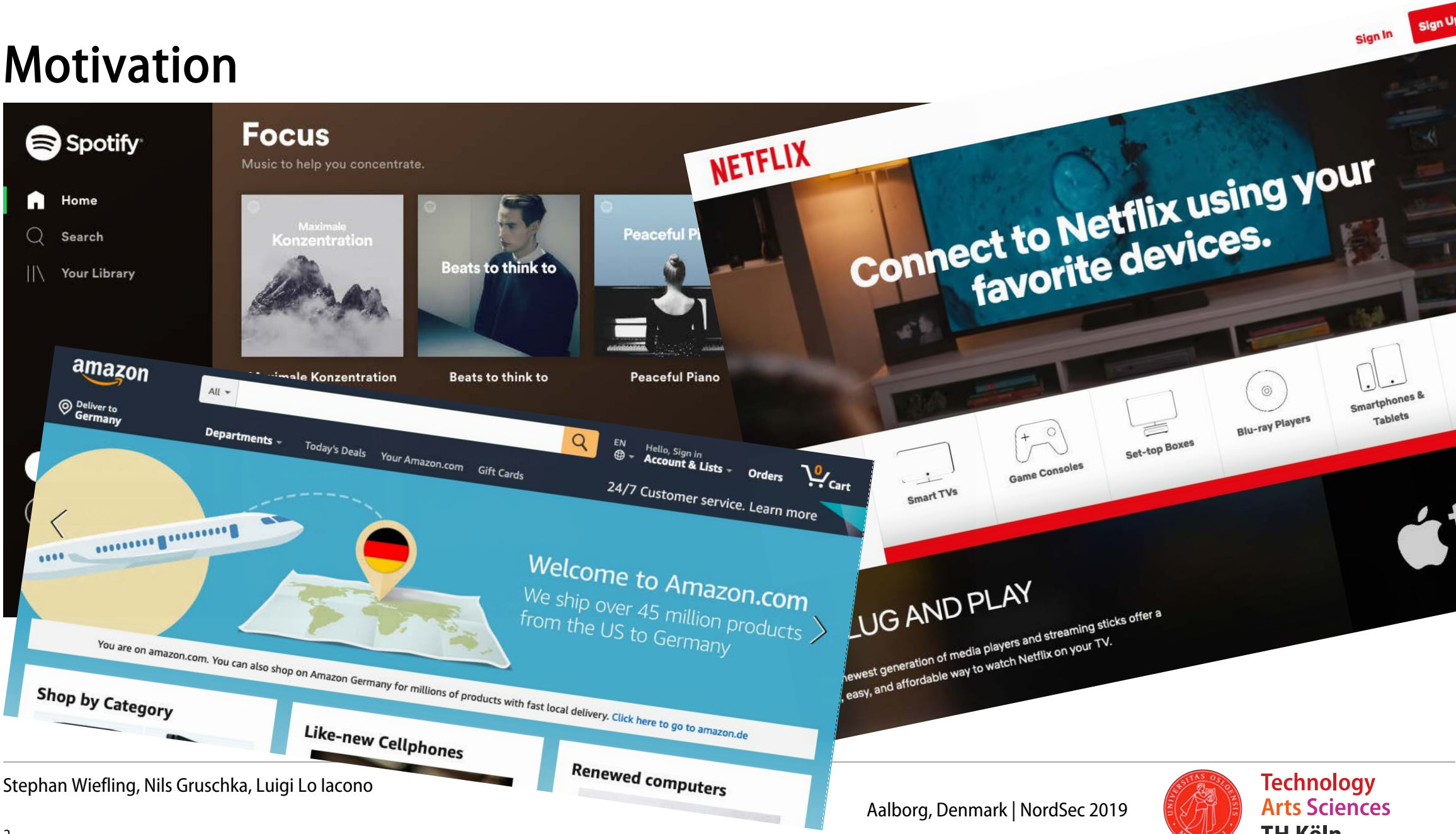
Even Turing Should Sometimes Not Be Able To Tell: Mimicking Humanoid Usage Behavior for Exploratory Studies of Online Services

Stephan Wiefling[1], Nils Gruschka[2], Luigi Lo Iacono[1]

[1] TH Köln – University of Applied Sciences
[2] University of Oslo

Motivation


Spotify
Home
Search
Your Library
Focus
Music to help you concentrate.
Maximale Konzentration
Beats to think to
Peaceful Piano
NETFLIX
Sign In
Connect to Netflix using your favorite devices.
Smart TVs
Game Consoles
Set-top Boxes
Blu-ray Players
Smartphones & Tablets
LUG AND PLAY
amazon
Deliver to Germany
Departments
Today's Deals
Your Amazon.com
Gift Cards
Hello, Sign in
Account & Lists
Orders
Cart
24/7 Customer service. Learn more
Welcome to Amazon.com
We ship over 45 million products from the US to Germany
You are on amazon.com. You can also shop on Amazon Germany for millions of products with fast local delivery. Click here to go to amazon.de
Shop by Category
Like-new Cellphones
Renewed computers

Motivation

- Algorithms impact our society
- Technical aspects hidden behind user interfaces
- Data availability needed for reliable research

Motivation

- Most online services are black boxes
- Lack of transparency hinders research
- Reverse engineering needed

Reverse engineering is complicated…

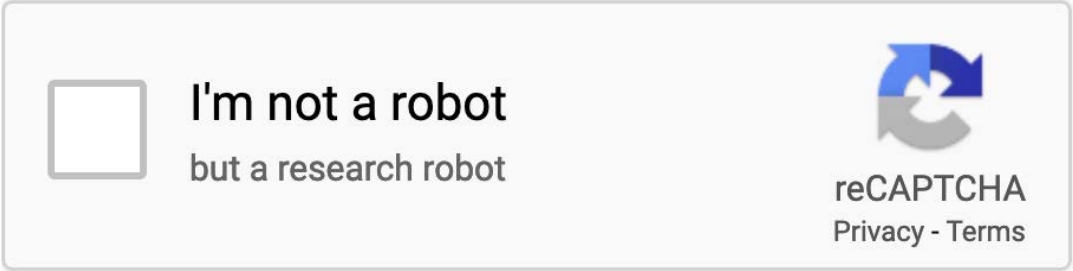
Reverse engineering is complicated…

- No unique path to conduct such an analysis
- Services implement countermeasures

Reverse engineering is complicated…

- No unique path to conduct such an analysis
- Services implement countermeasures

→Camouflage measures needed



HOSIT

Humanoid Online Service Inspection Tool

Overview

1. Tool

↓

2. Proof of Concept

↓

3. Conclusion

Inspection Tool

- Simulates human-like browsing behavior on online services
- All actions have to be predefined by the researchers
  - Reliable and reproducible research
- Based on Puppeteer API

Inspection Tool

Virtual Identities

- Define properties
  - Typing, clicking behavior
  - Interests
  - …

Training Procedures

- New accounts are considered suspicious
- Need to create valid behavior first
- Takes time

Training Procedures

- Define activities to be performed on online service
  - and other online services (tracking)
- Executed multiple times

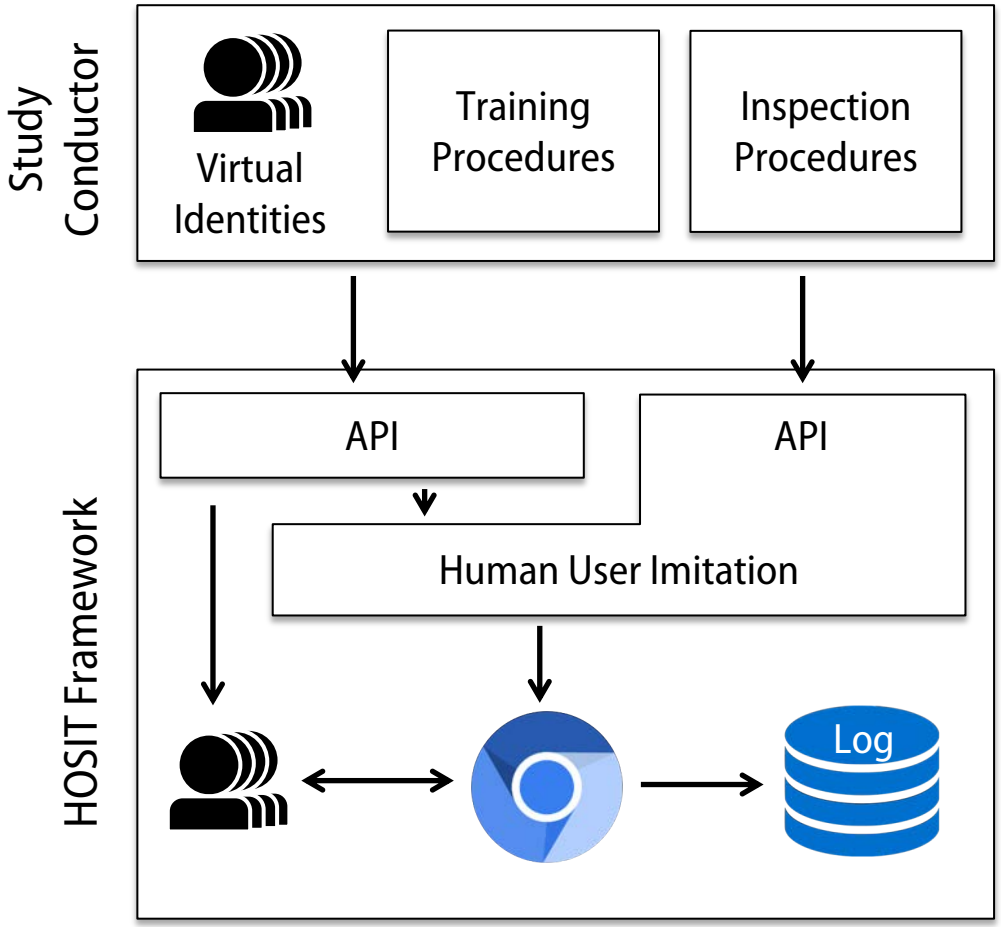
Training Procedures

- Let the service learn “normal” behavior
- Get tracked on other websites by the service
- Desired result:
  - Get labeled as “normal” user

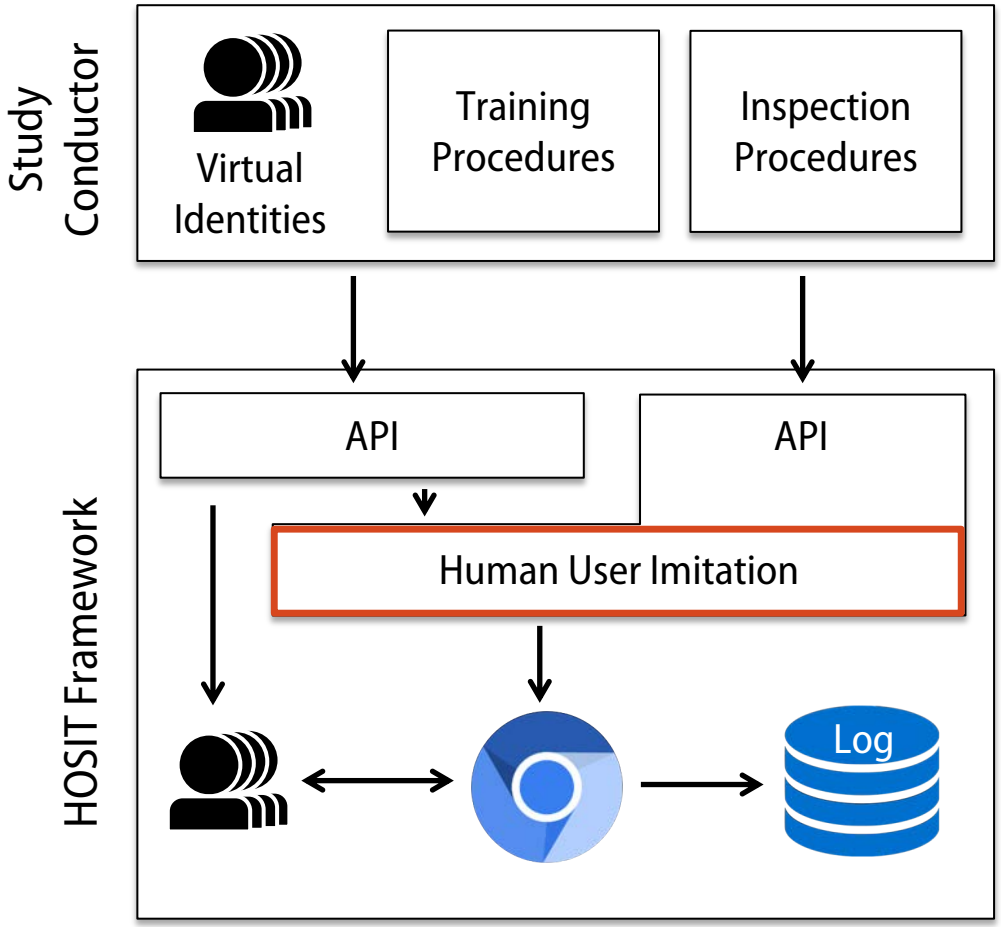
Inspection Procedures

- Create unusual behavior at online service
- Analyze services' reaction to unusual behavior

Inspection Tool

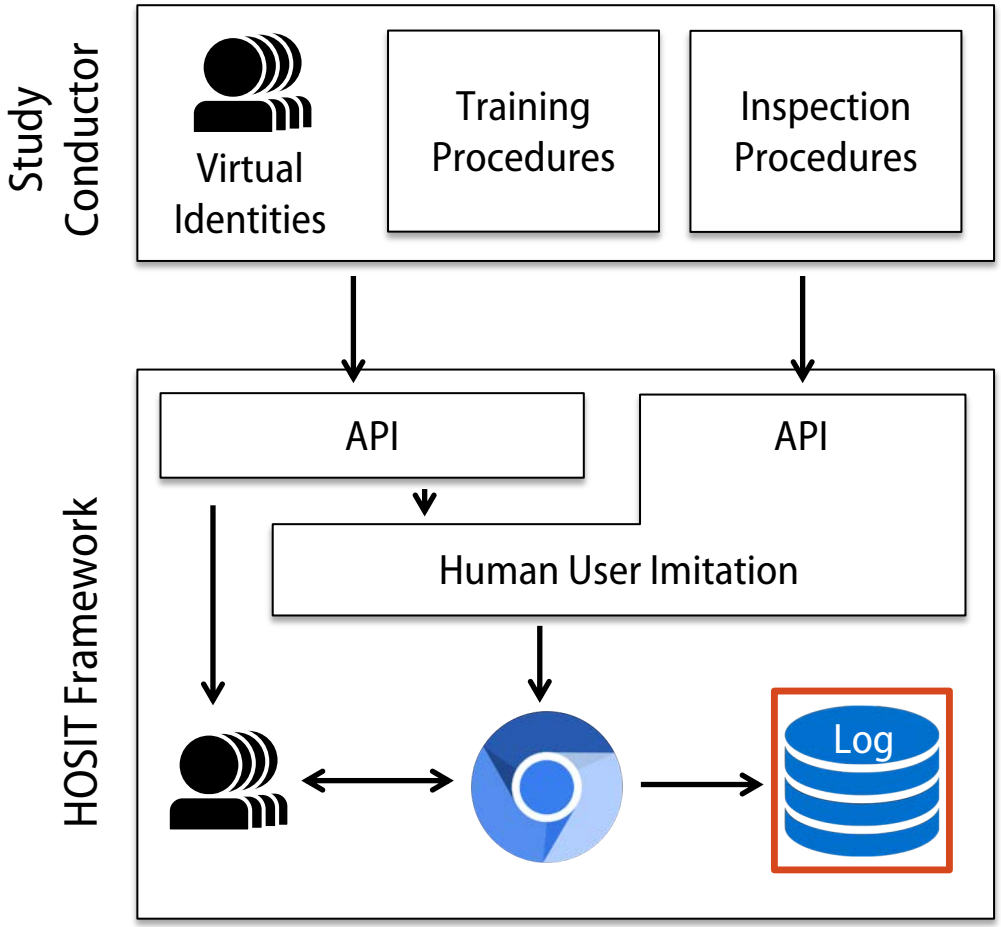


Inspection Tool



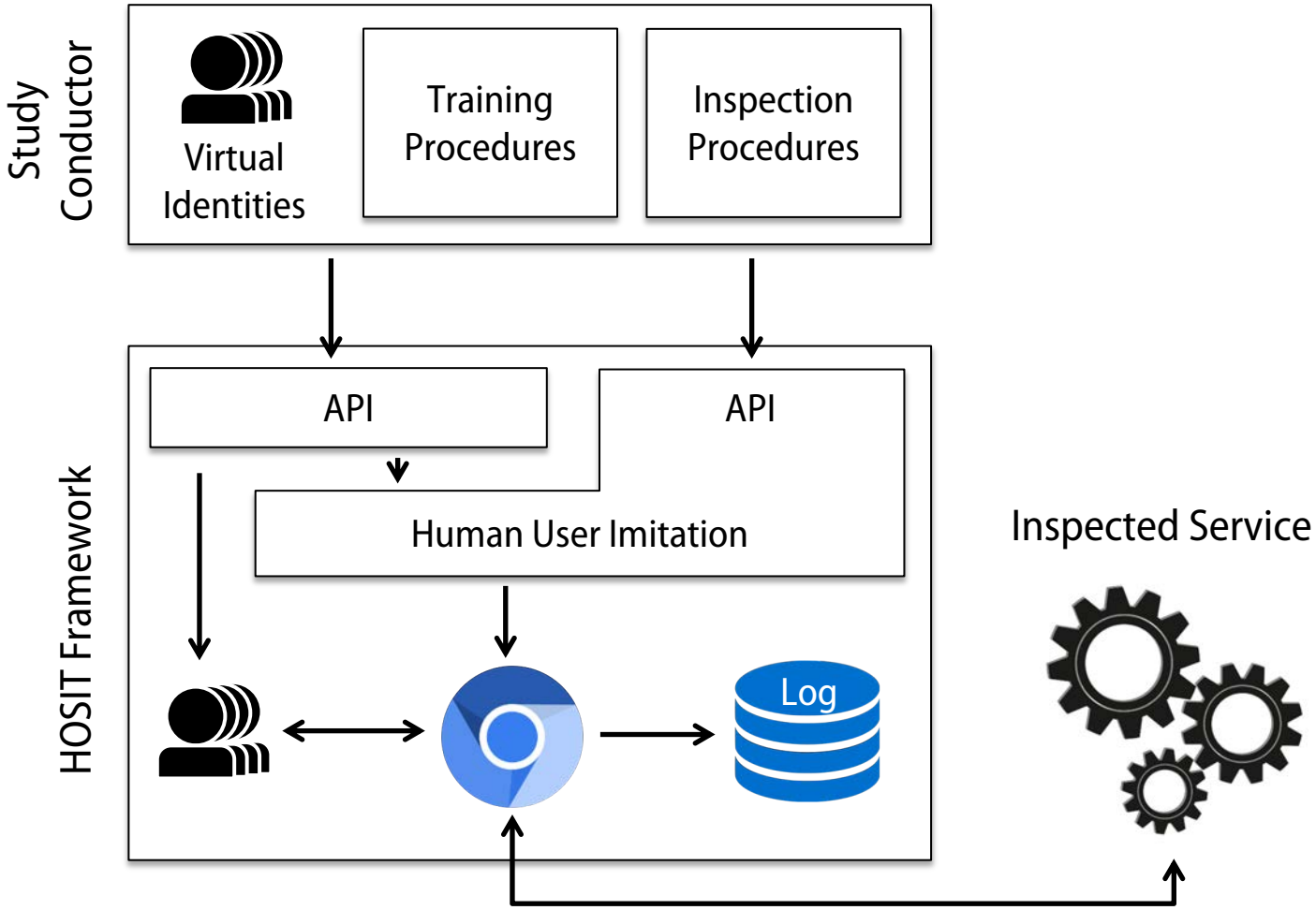
- Executes the actions
- Adds human-imitating behavior to function calls
- Properties of virtual identity

Inspection Tool



- Logs all actions with screenshots
- Reproducibility

Inspection Tool



Why do we need another browser automation tool?

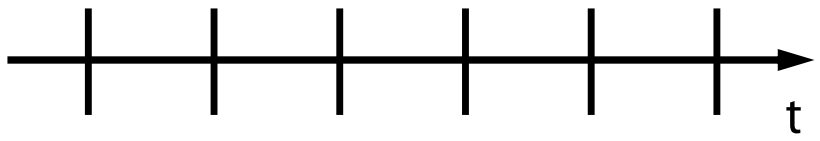
Click Behavior

Puppeteer 0.13.0

HOSIT *

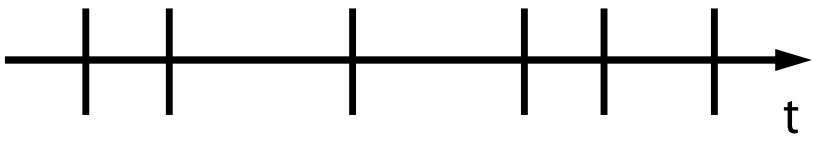
* Komandur et al.: Relation between mouse button click duration and muscle contraction time. In: EMBC '08. (Aug 2008)

Typing Speed



Constant delay

Puppeteer 0.13.0

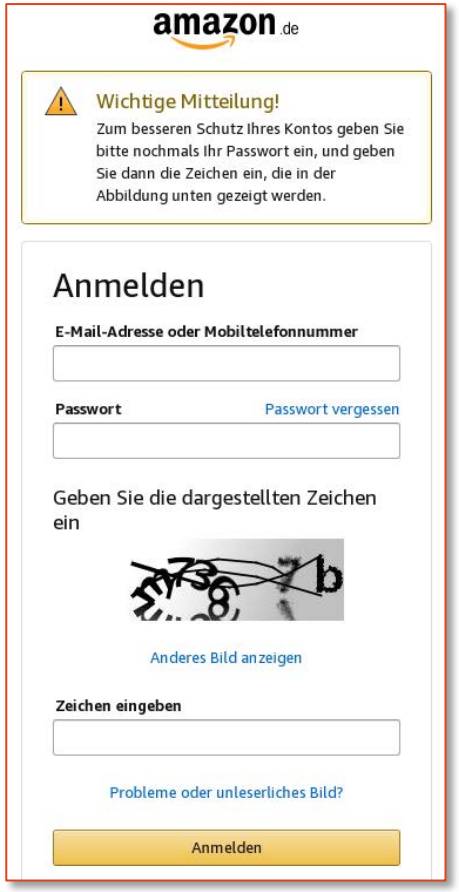


Randomized variations*

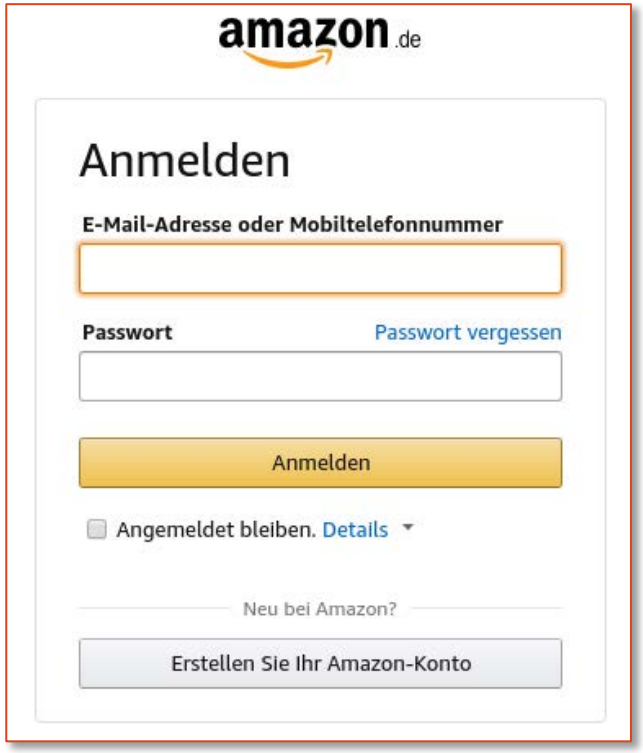
HOSIT

* Drury, C.G., Hoffmann, E.R.: A model for movement time on data-entry keyboards. Ergonomics 35(2) (Feb 1992)

Bot Detection Protection



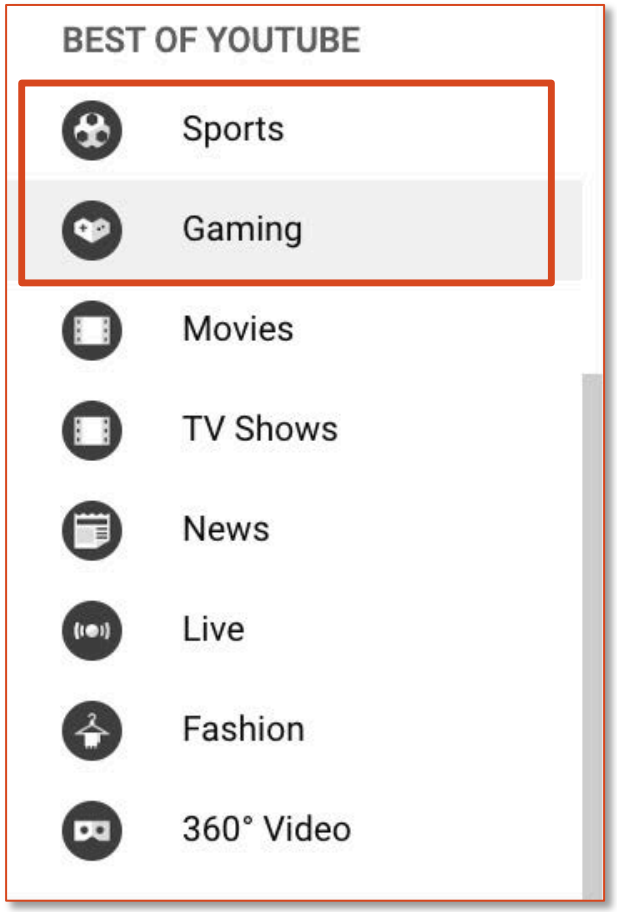
Puppeteer 0.13.0



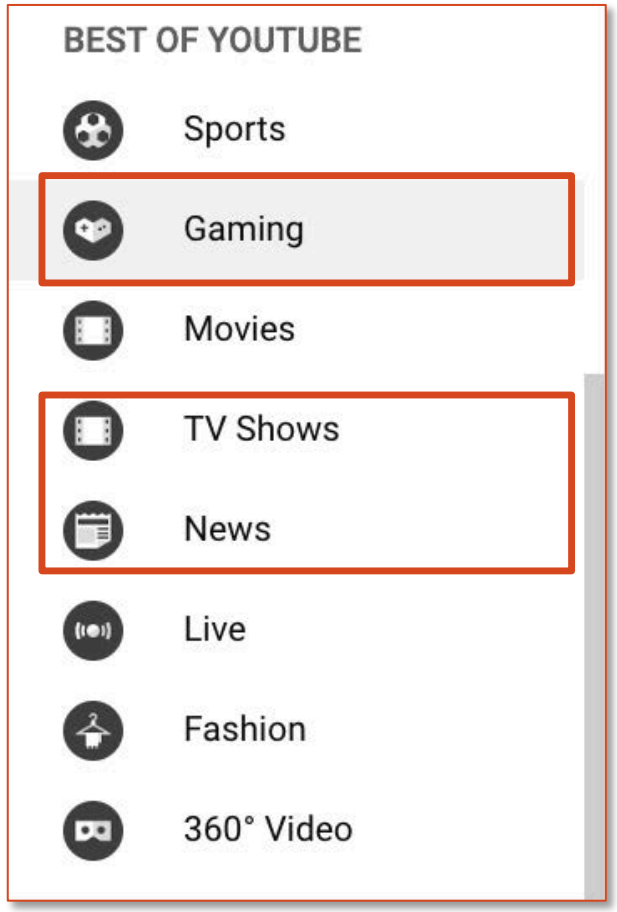
HOSIT

Browsing Behavior Changes

Persona A



Persona B



More Functions

- Common workflows integrated
- Search query generator
- CAPTCHA solving
- Scrolling
- Select tabs

Example Script

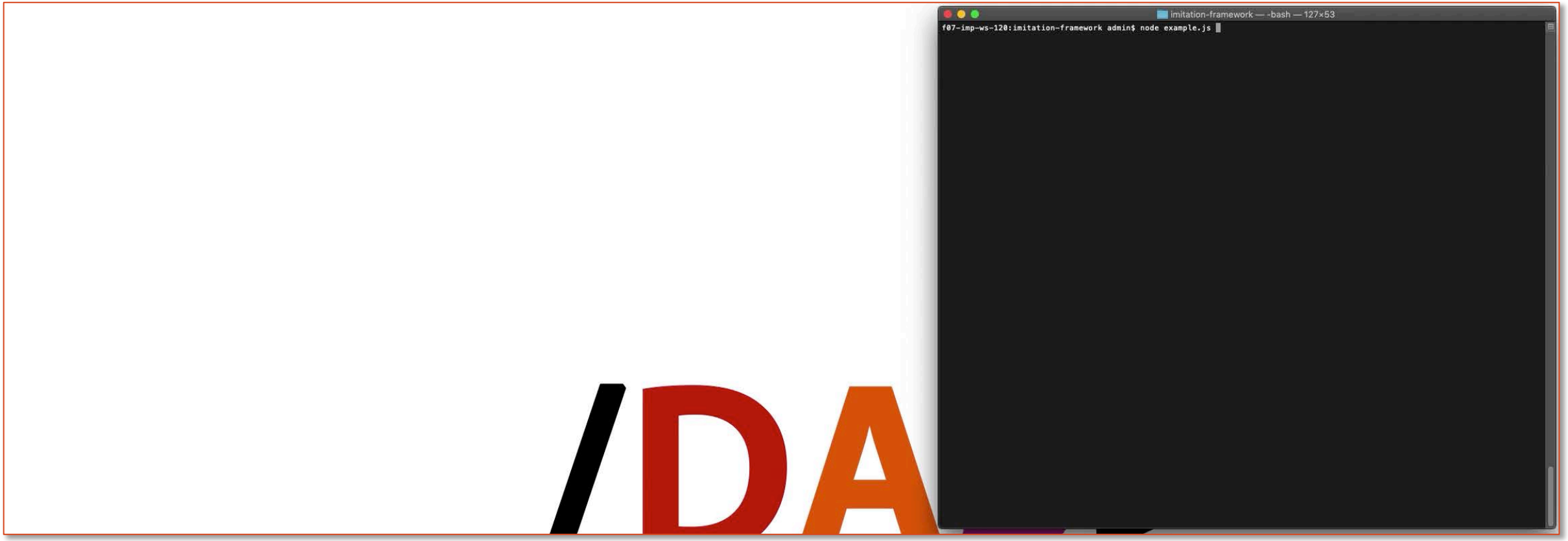
- Opens a search engine
- Clicks on image search
- Types random search query covered in the media
- Scrolls to bottom of results

```
// Open new page tab
await controller.newPage("https://www.startpage.com/");

// Wait a random time period
await controller.randomWait();

// Click on the "Images"-Link
await controller.click("a[href='https://www.startpage.com/
    en/pics.html']");

// Wait until the text field is loaded
await controller.waitForSelector("input[type='text']");

// Generate and enter search query based on
// current events in media
await controller.typeSearchQuery("input[type='text']");

// Scroll to the bottom of the page
await controller.scrollToBottom();
```

Example Script

- Video recorded at October 22nd, 2019

```
// Open new page tab
await controller.newPage("https://www.startpage.com/");

// Wait a random time period
await controller.randomWait();

// Click on the "Images"-Link
await controller.click("a[href='https://www.startpage.com/
    en/pics.html']");

// Wait until the text field is loaded
await controller.waitForSelector("input[type='text']");

// Generate and enter search query based on
// current events in media
await controller.typeSearchQuery("input[type='text']");

// Scroll to the bottom of the page
await controller.scrollToBottom();
```



Overview

1. Tool

↓

2. **Proof of Concept**

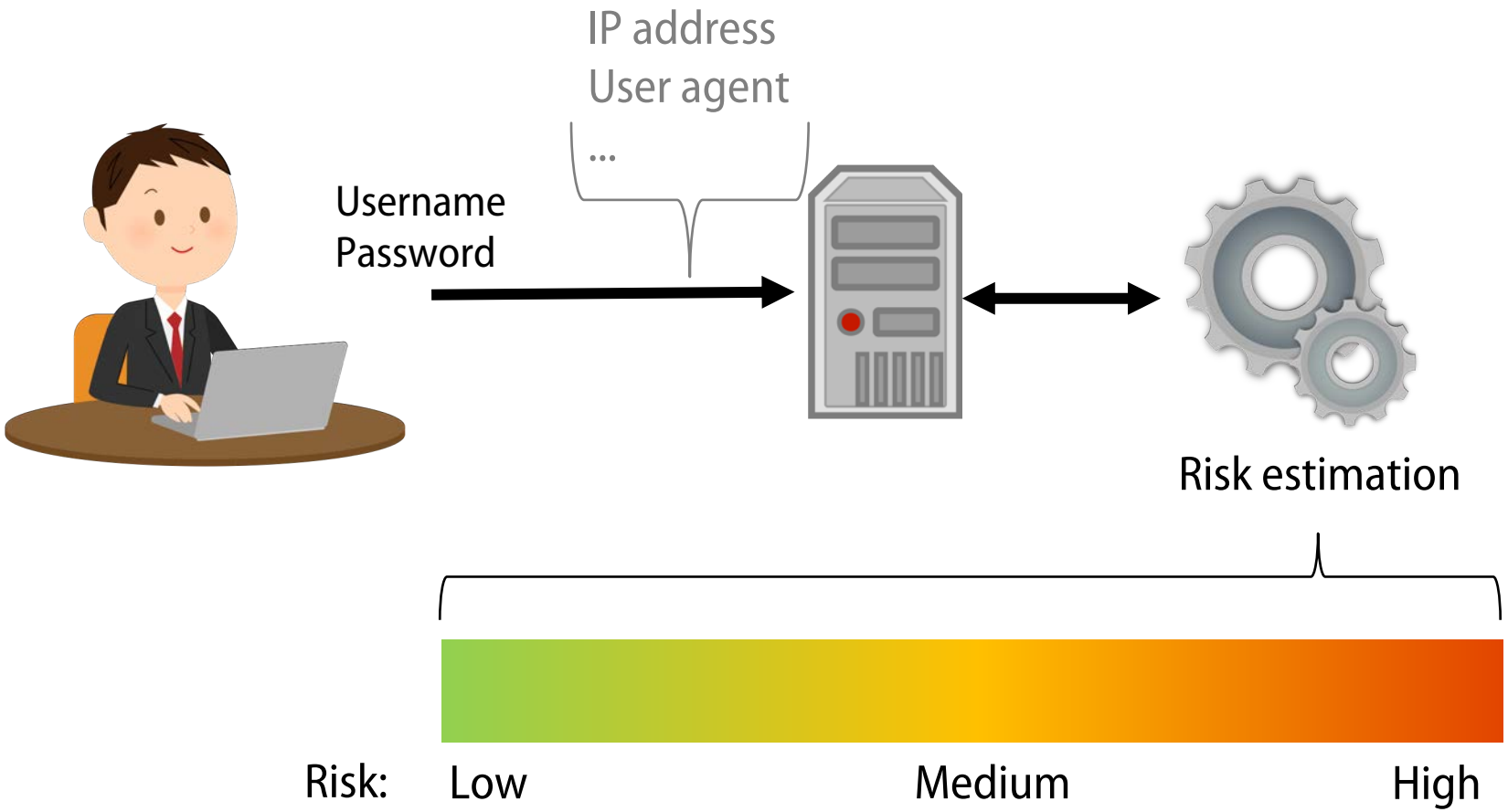
↓

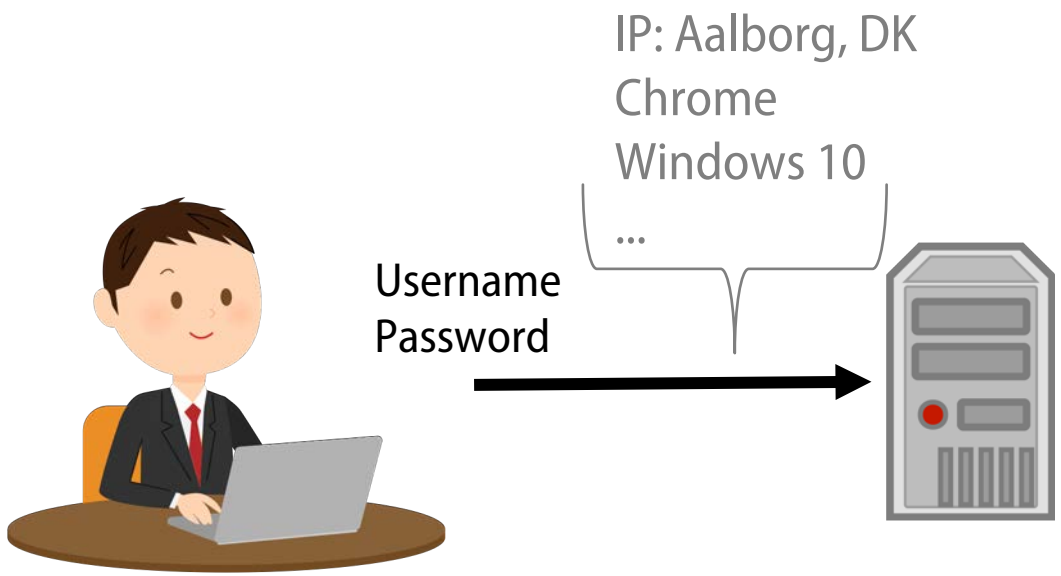
3. Conclusion

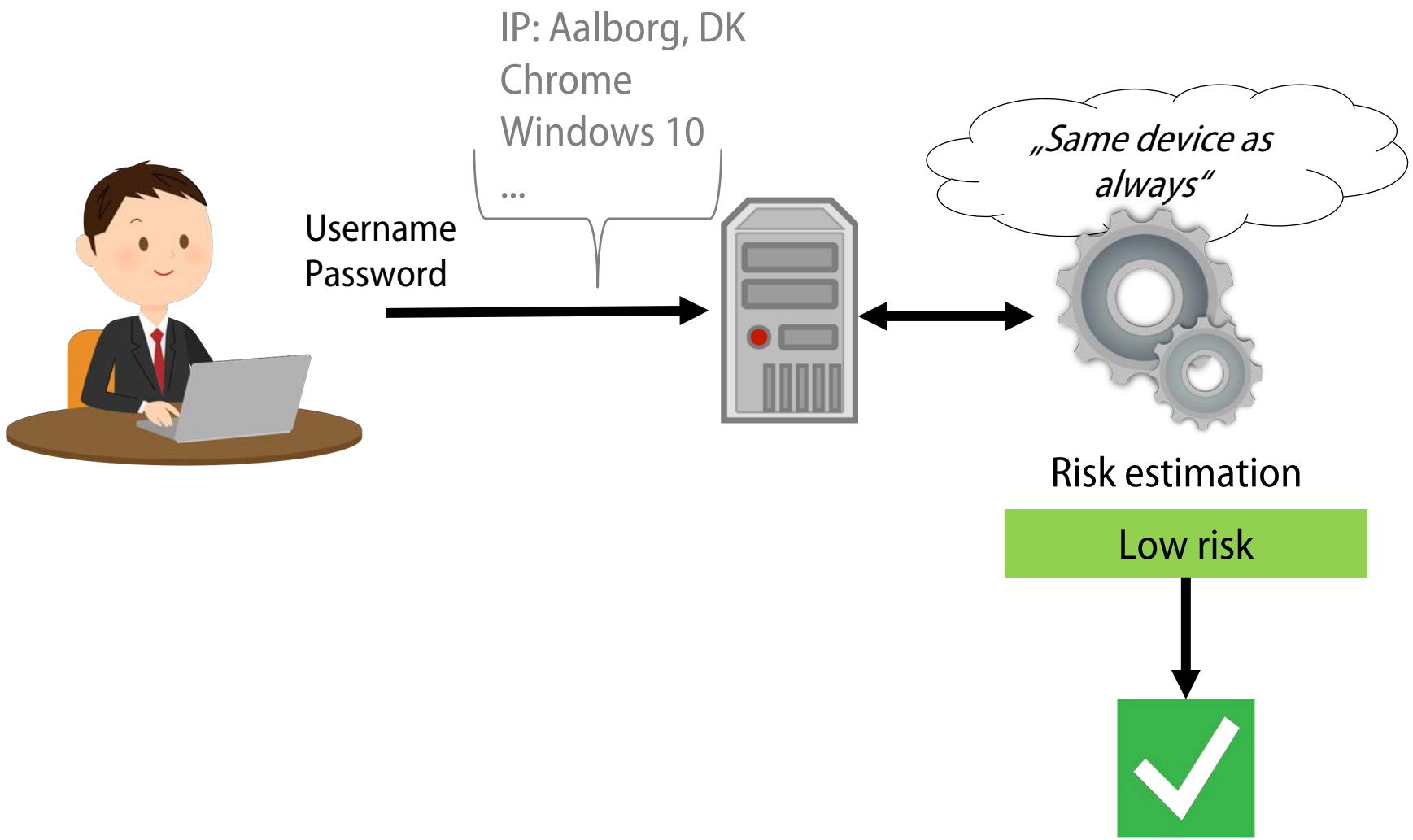
Proof of Concept

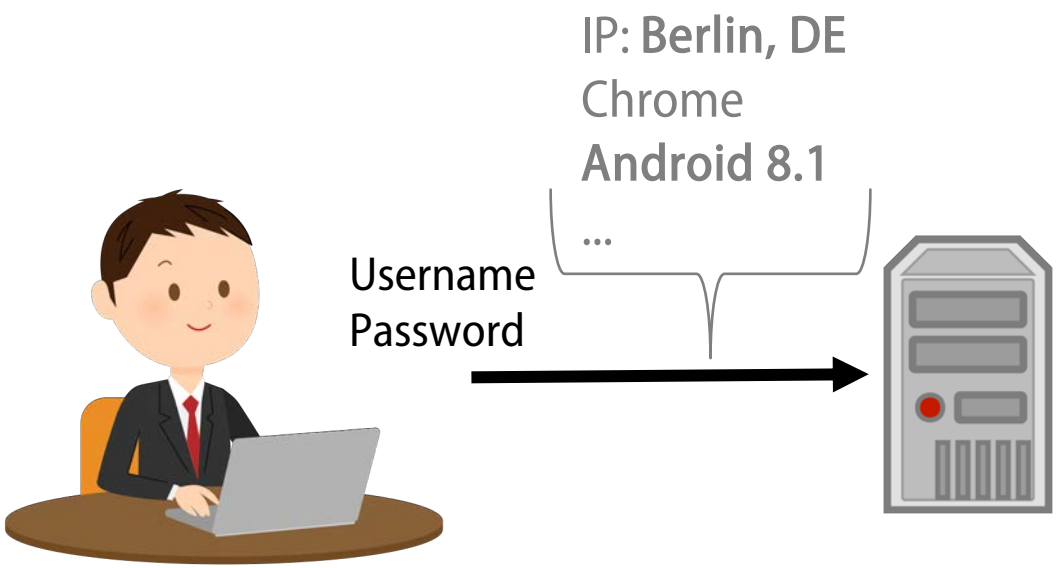
- Study on Risk-based Authentication*
- Required human-like behavior from clients

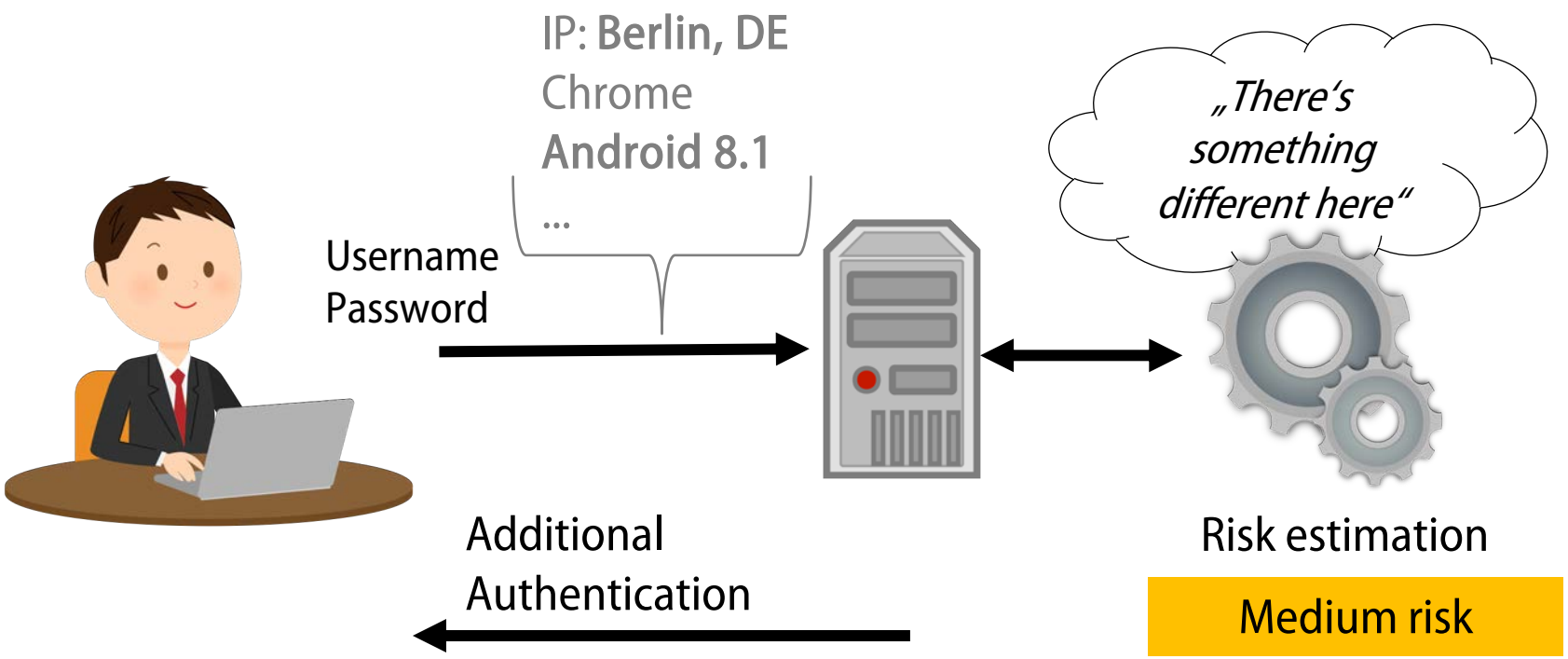
* Wiefling et al.: Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild. In: IFIP SEC '19. (Jun 2019)

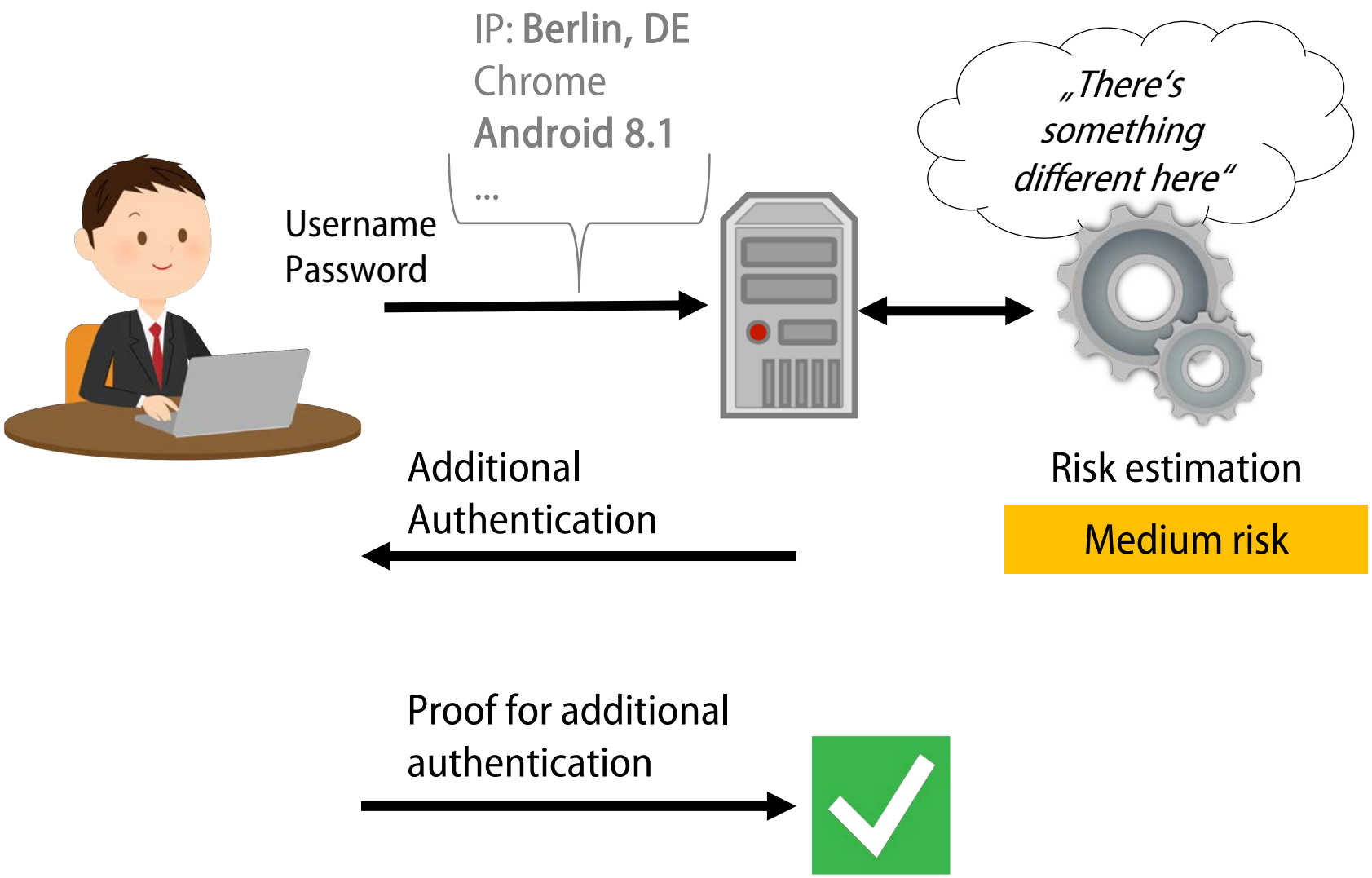

IP address
User agent
...
Username
Password
Risk estimation
Risk:
Low
Medium
High

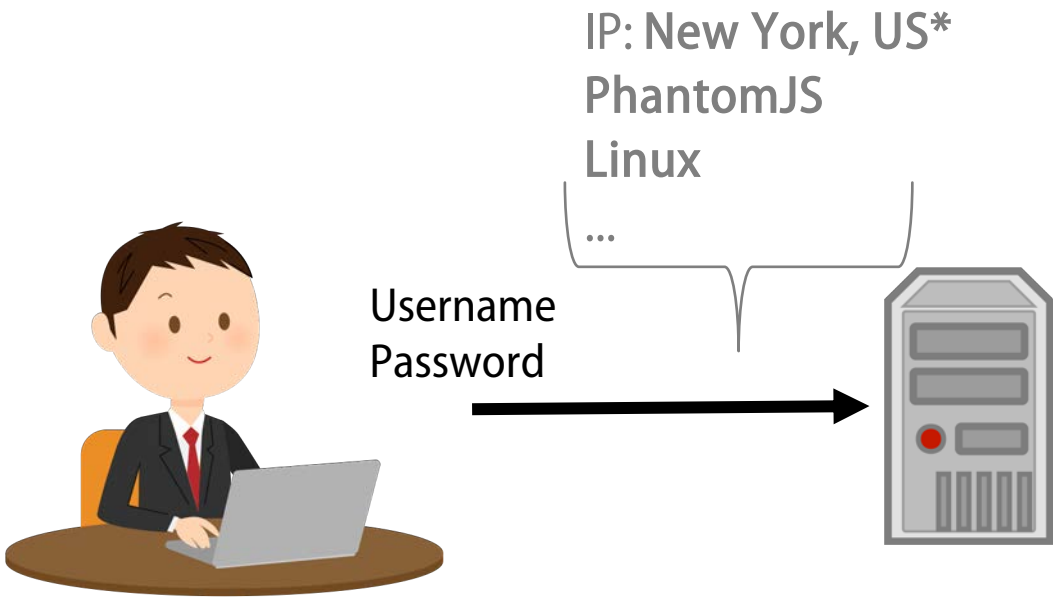

IP: Aalborg, DK
Chrome
Windows 10
...
Username
Password


IP: Aalborg, DK
Chrome
Windows 10
...
Username
Password
„Same device as always“
Risk estimation
Low risk

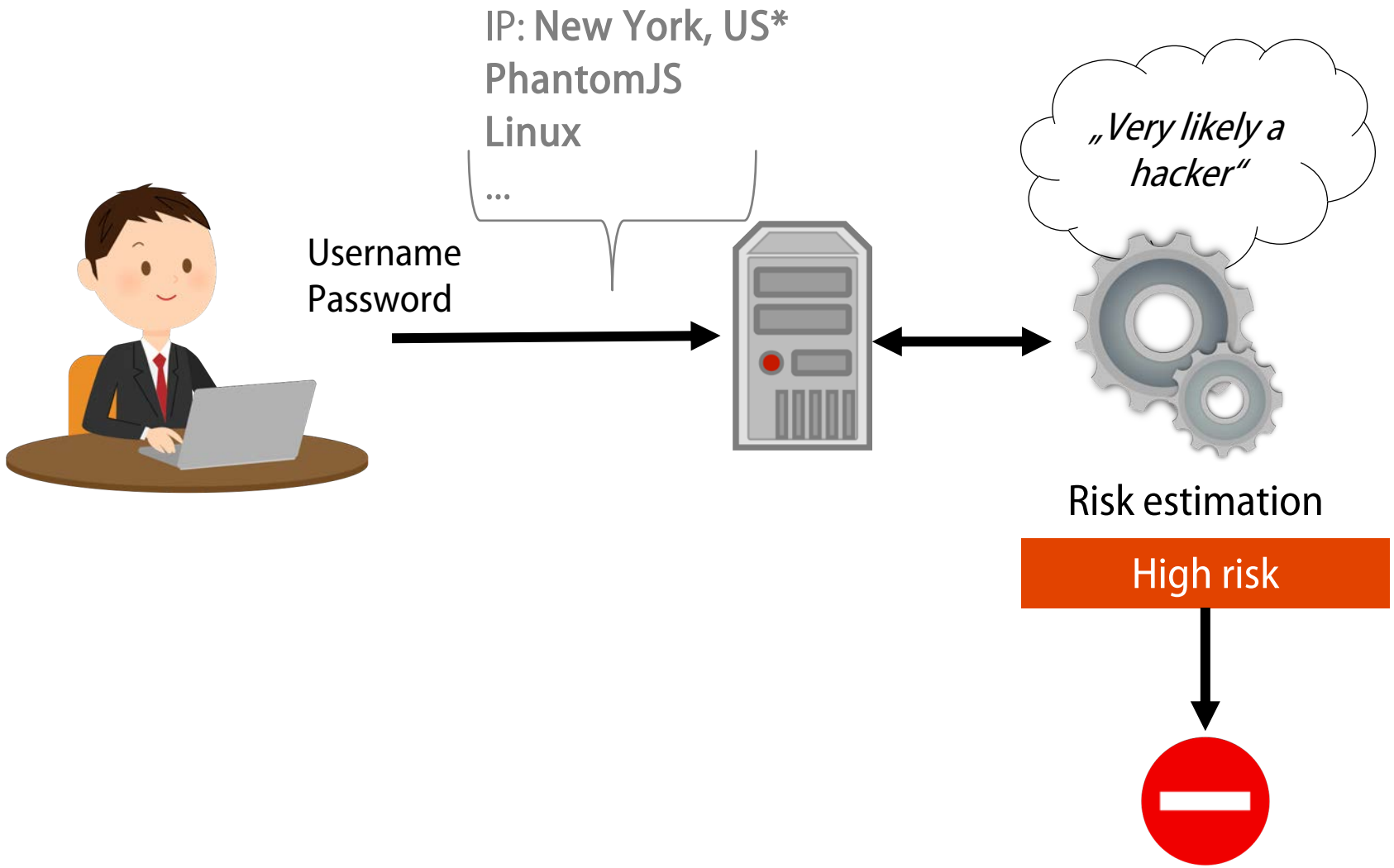

IP: Berlin, DE
Chrome
Android 8.1
...
Username
Password


IP: Berlin, DE
Chrome
Android 8.1
...
Username
Password
„There's something different here"
Additional Authentication
Risk estimation
Medium risk


IP: Berlin, DE
Chrome
Android 8.1
...
Username
Password
„There's something different here"
Additional Authentication
Risk estimation
Medium risk
Proof for additional authentication



* Known spam IP address



* Known spam IP address

Risk-based Authentication

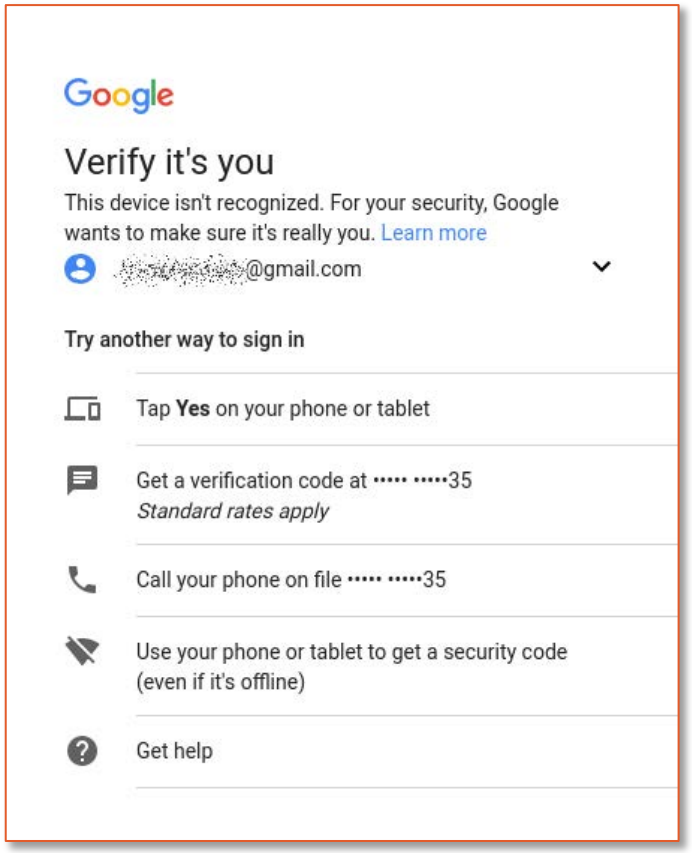
- Recommended by NIST digital identity guidelines*
- Used by large online services
- However: Procedures not disclosed

→ Black-box testing eight popular online services

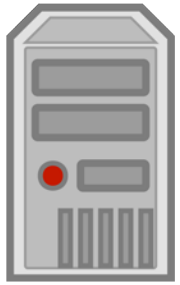
* Grassi et al.: Digital identity guidelines. Tech. Rep. NIST SP 800-63b (2017)

Proof of Concept*

- Trained services with human-like behavior
- Triggered RBA with behavior



* Wiefling et al.: Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild. In: IFIP SEC '19. (Jun 2019)



?

?

Login	IP address	User Agent	...

Login →

Login	IP address	User Agent	...
1	TH Köln	Chrome	...

Login →

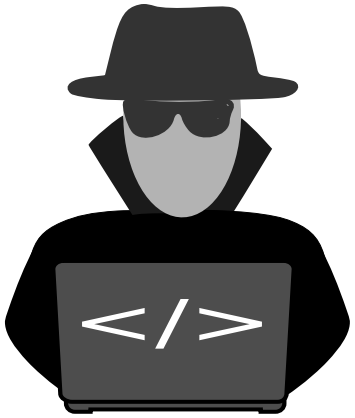
Login	IP address	User Agent	...
1	TH Köln	Chrome	...
2	TH Köln	Chrome	...

Login →

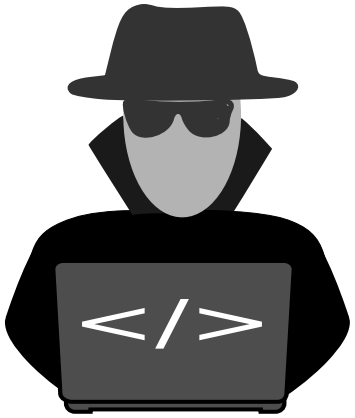
Login	IP address	User Agent	...
1	TH Köln	Chrome	...
2	TH Köln	Chrome	...
3	TH Köln	Chrome	...

Login → ?

Login	IP address	User Agent	...
1	TH Köln	Chrome	...
2	TH Köln	Chrome	...
3	TH Köln	Chrome	...
...	...	...	....
20	TH Köln	Chrome	...

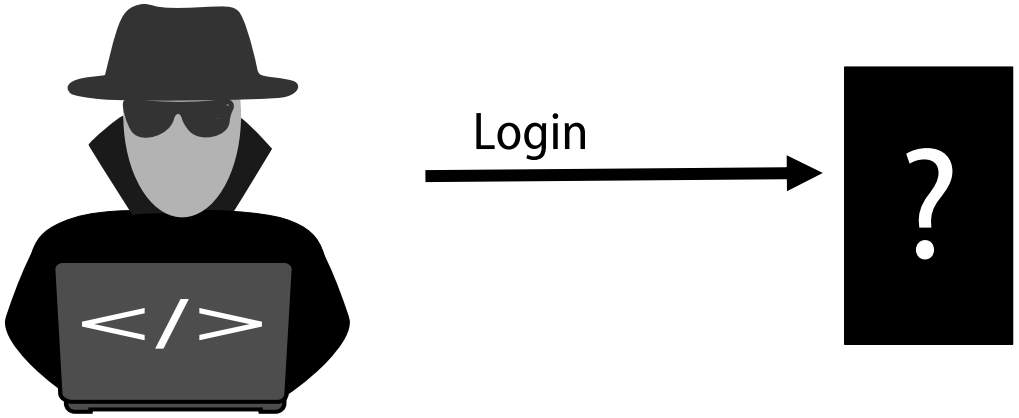


Login	IP address	User Agent	...
1	TH Köln	Chrome	...
2	TH Köln	Chrome	...
3	TH Köln	Chrome	...
...	...	...	....
20	TH Köln	Chrome	...



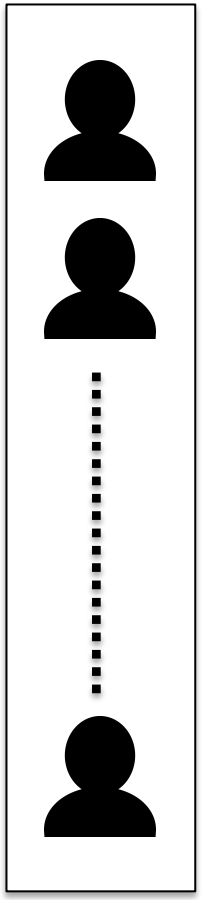
Login

Login	IP address	User Agent	...
1	TH Köln	Chrome	...
2	TH Köln	Chrome	...
3	TH Köln	Chrome	...
...	...	...	....
20	TH Köln	Chrome	...
21	**Other Country**	Chrome	...

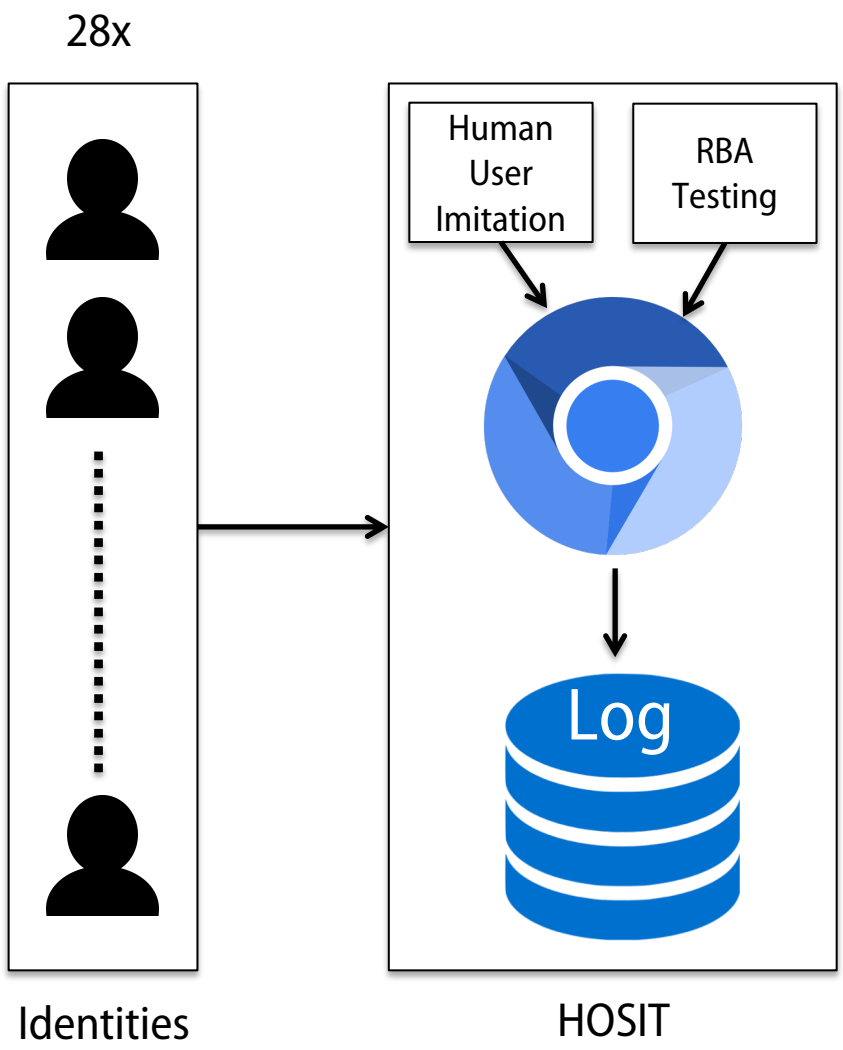


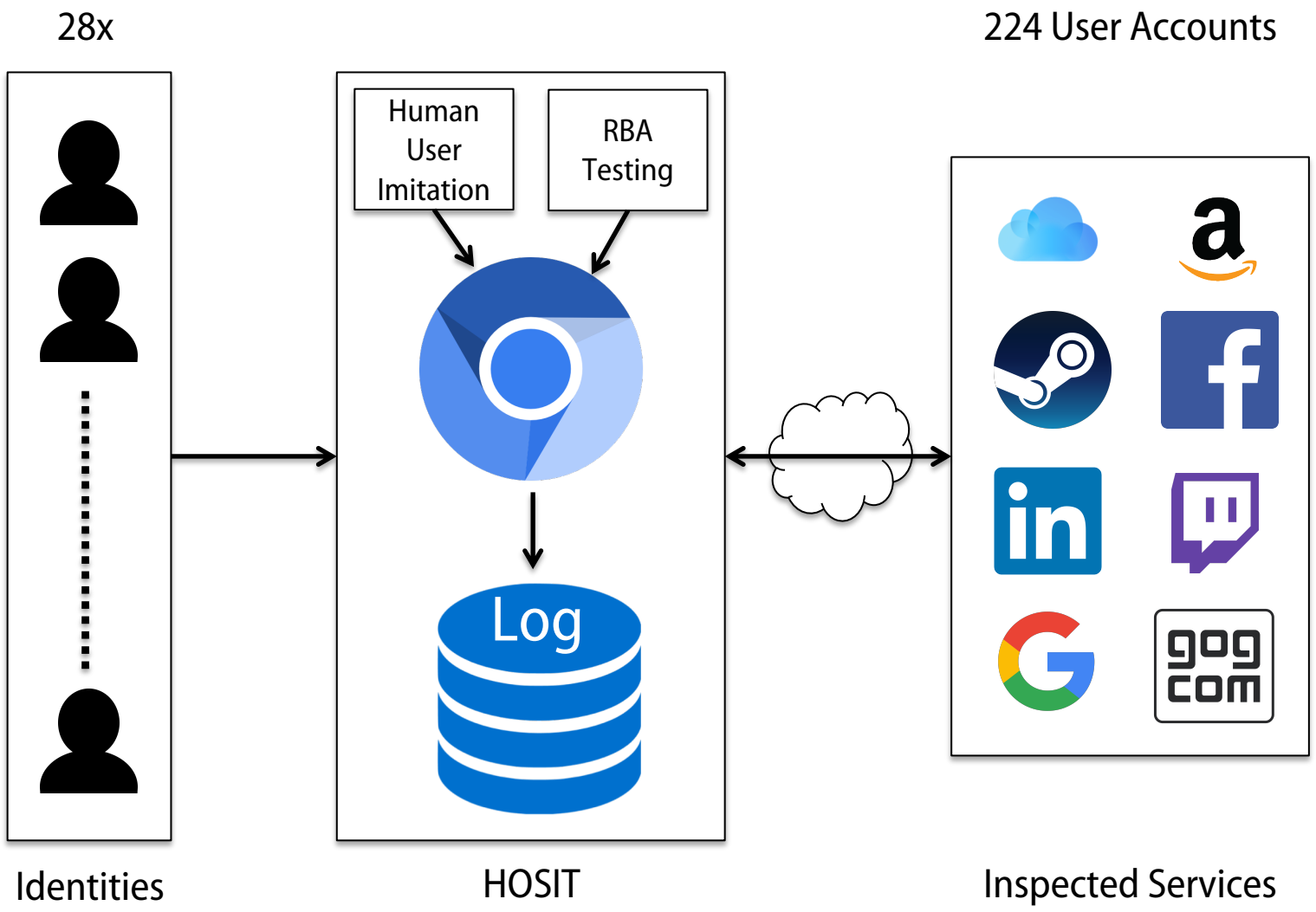
Login	IP address	User Agent	...
1	TH Köln	Chrome	...
2	TH Köln	Chrome	...
3	TH Köln	Chrome	...
...	...	...	....
20	TH Köln	Chrome	...
21	**Other Country**	Chrome	...

28x



Identities


28x
Human User Imitation
RBA Testing
Log
Identities
HOSIT


28x
224 User Accounts
Human User Imitation
RBA Testing
Log
Identities
HOSIT
Inspected Services

Proof of Concept*

- Results:
  - Internal features used for RBA
  - Estimation of services' RBA procedures
- Would not have been possible without HOSIT

* Wiefling et al.: Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild. In: IFIP SEC '19. (Jun 2019)

Overview

1. Tool
2. Proof of Concept
3. **Conclusion**

Conclusion

- HOSIT available as open source software*
- Can be used for own studies of online services
- Responsible service access for researchers?

* https://git.io/hosit

Thank you

riskbasedauthentication.org/hosit
das.th-koeln.de

stephan.wiefling@th-koeln.de

@swiefling